

TEMA 1: Sistemas de almacenamiento de la información

Legislación sobre protección de
datos

IES Isidra de Guzmán	 IES Isidra de Guzmán
Desarrollo Aplicaciones Multiplataforma	Curso 2025/2026
Tema 1: Sistemas de almacenamiento de la información	Legislación sobre protección de datos

Contenido

1. Introducción	3
2. Reglamento General de Protección de Datos (RGPD)	3
2.1. Principios clave.....	3
2.2. Obligaciones y documentos necesarios para cumplir RGPD	4
2.2.1. Ejemplo de aplicación del RGPD	8
3. Ley Orgánica de Protección de Datos y Garantía de los Derechos Digitales (LOPDGDD)	10
3.1. Derechos de los titulares de datos.....	14
3.2. Responsabilidad proactiva y evaluaciones de impacto	17
3.2.1. Medidas proactivas que deben tomar los administradores de bases de datos ...	17
3.3. Evaluaciones de Impacto en la Protección de Datos (EIPD)	18
3.3.1. Pasos para realizar una EIPD	19
3.4. Notificación de brechas de seguridad.....	21
3.4.1. Tipos comunes de brechas de seguridad.....	21
3.4.2. Proceso de notificación de una brecha de seguridad	21

IES Isidra de Guzmán	 IES Isidra de Guzmán
Desarrollo Aplicaciones Multiplataforma	Curso 2025/2026
Tema 1: Sistemas de almacenamiento de la información	Legislación sobre protección de datos

1. Introducción

La protección de datos garantiza la privacidad de las personas en el uso de sus datos personales. Es esencial en la era digital, especialmente en bases de datos, para asegurar el cumplimiento normativo y evitar sanciones. Su objetivo es evitar la vulneración de los derechos fundamentales de los ciudadanos en el manejo de su información.

2. Reglamento General de Protección de Datos (RGPD)

El RGPD es el reglamento más importante en materia de protección de datos en la Unión Europea. Se aplica a cualquier organización que maneje datos personales de ciudadanos de la UE.

2.1. Principios clave

Algunos de los principios clave del RGPD son:

1. Licitud, lealtad y transparencia

- **Licitud:** El tratamiento de datos debe estar basado en una de las bases legales definidas por el RGPD, como el consentimiento, el cumplimiento de una obligación legal, o la ejecución de un contrato.
- **Lealtad:** Los datos deben tratarse de forma justa y honesta.
- **Transparencia:** Los usuarios deben ser informados de forma clara y sencilla sobre cómo se usarán sus datos

2. Limitación de la finalidad

- Los datos personales solo pueden recopilarse para fines específicos, explícitos y legítimos. No pueden ser utilizados para otro propósito que no haya sido previamente informado al usuario.

3. Minimización de datos

- Solo se deben recolectar los datos personales estrictamente necesarios para el fin por el cual fueron recopilados. No se deben procesar datos innecesarios o excesivos.

4. Exactitud

IES Isidra de Guzmán	 IES Isidra de Guzmán
Desarrollo Aplicaciones Multiplataforma	Curso 2025/2026
Tema 1: Sistemas de almacenamiento de la información	Legislación sobre protección de datos

- Los datos deben ser precisos y estar actualizados. Es responsabilidad del responsable del tratamiento corregir o eliminar cualquier dato inexacto o desactualizado.

5. Limitación del plazo de conservación

- Los datos personales solo deben almacenarse durante el tiempo que sea necesario para cumplir con la finalidad para la cual fueron recopilados. Una vez cumplida la finalidad, los datos deben eliminarse o anonimizarse.

6. Integridad y confidencialidad

- Los datos deben ser tratados de manera que se garantice su seguridad, lo que implica protegerlos contra el acceso no autorizado, pérdida, destrucción o daño accidental. Esto se logra a través de medidas técnicas y organizativas adecuadas.

7. Responsabilidad proactiva (Accountability)

- El responsable del tratamiento debe poder demostrar que cumple con todos los principios del RGPD. Esto implica adoptar políticas adecuadas, realizar evaluaciones de impacto, y documentar los procesos de tratamiento de datos.

2.2. Obligaciones y documentos necesarios para cumplir RGPD

Para cumplir con el **Reglamento General de Protección de Datos (RGPD)**, las organizaciones deben seguir una serie de obligaciones y crear ciertos documentos que garanticen el correcto tratamiento de los datos personales.

A continuación, se enumeran todas las obligaciones y los documentos necesarios para cumplir con el RGPD:

1. Política de privacidad

- **Obligación:** La empresa debe proporcionar a los usuarios información clara y accesible sobre cómo se recopilan, utilizan, almacenan y comparten sus datos.
- **Documento: Política de privacidad.** Este documento debe incluir: Quién es el responsable del tratamiento de los datos.
 - Qué datos personales se recopilan.
 - Para qué fines se recopilan y la base legal para su tratamiento.
 - Cuánto tiempo se almacenarán los datos.
 - Derechos del usuario (acceso, rectificación, supresión, etc.).
 - Información sobre posibles transferencias de datos a terceros.
 - Información de contacto para ejercer los derechos de los usuarios.

IES Isidra de Guzmán	 IES Isidra de Guzmán
Desarrollo Aplicaciones Multiplataforma	Curso 2025/2026
Tema 1: Sistemas de almacenamiento de la información	Legislación sobre protección de datos

2. Consentimiento explícito

- **Obligación:** La empresa debe obtener el consentimiento explícito de los usuarios antes de tratar sus datos en casos donde no exista otra base legal. Este consentimiento debe ser libre, informado, específico y verificable.
- **Documento: Registro de consentimiento.** Este documento puede ser digital o físico, y debe demostrar que el consentimiento se obtuvo de forma válida. Las casillas premarcadas no son válidas.

3. Contrato de encargado del tratamiento

- **Obligación:** Si una empresa comparte datos personales con terceros (por ejemplo, con proveedores de servicios de almacenamiento o marketing), debe firmar un contrato que garantice que el proveedor también cumple con el RGPD.
- **Documento: Contrato de encargado del tratamiento.** Este contrato debe incluir:
 - Instrucciones precisas sobre el tratamiento de datos.
 - Garantías de que el proveedor aplicará medidas adecuadas de seguridad.
 - Una obligación del encargado de ayudar al responsable en el cumplimiento de sus obligaciones bajo el RGPD (por ejemplo, notificación de brechas de seguridad).

4. Evaluación de impacto en la protección de datos (EIPD)

- **Obligación:** Si el tratamiento de datos supone un alto riesgo para los derechos y libertades de las personas (por ejemplo, cuando se manejan grandes volúmenes de datos sensibles), es necesario realizar una evaluación de impacto.
- **Documento: Evaluación de impacto en la protección de datos (EIPD).** Este documento debe detallar:
 - Descripción del tratamiento de datos.
 - Evaluación de la necesidad y proporcionalidad del tratamiento.
 - Evaluación de los riesgos para los derechos de los usuarios.
 - Medidas que se adoptarán para mitigar los riesgos identificados.

5. Registro de actividades de tratamiento

- **Obligación:** Las organizaciones que traten datos personales de forma regular deben llevar un registro de todas las actividades de tratamiento de datos.
- **Documento: Registro de actividades de tratamiento.** Este registro debe incluir:

IES Isidra de Guzmán	 IES Isidra de Guzmán
Desarrollo Aplicaciones Multiplataforma	Curso 2025/2026
Tema 1: Sistemas de almacenamiento de la información	Legislación sobre protección de datos

- El nombre y datos del responsable del tratamiento.
- Los fines del tratamiento.
- Descripción de las categorías de datos tratados y de las personas afectadas.
- Los destinatarios de los datos.
- El período durante el cual se conservarán los datos.
- Las medidas de seguridad implementadas.

6. Medidas de seguridad

- **Obligación:** La empresa debe garantizar que los datos personales estén protegidos contra accesos no autorizados, pérdida, destrucción o alteración.
- **Documento: Política de seguridad.** Este documento debe detallar las medidas técnicas y organizativas adoptadas para garantizar la seguridad de los datos. Puede incluir:
 - Cifrado de datos.
 - Control de acceso (solo personal autorizado puede acceder a ciertos datos).
 - Copias de seguridad periódicas.
 - Protocolo de respuesta ante incidentes de seguridad.

7. Notificación de brechas de seguridad

- **Obligación:** En caso de una violación de la seguridad que afecte los datos personales, la empresa debe notificar a la autoridad de protección de datos y, en su caso, a los afectados, en un plazo máximo de 72 horas.
- **Documento: Notificación de brechas de seguridad.** Este informe debe incluir:
 - Naturaleza de la brecha.
 - Categorías y número aproximado de datos y personas afectadas.
 - Consecuencias probables de la brecha.
 - Medidas adoptadas para mitigar la brecha.

8. Política de cookies y consentimiento

IES Isidra de Guzmán	 IES Isidra de Guzmán
Desarrollo Aplicaciones Multiplataforma	Curso 2025/2026
Tema 1: Sistemas de almacenamiento de la información	Legislación sobre protección de datos

- **Obligación:** Si una empresa utiliza cookies en su sitio web para recoger información de los usuarios, debe informarles claramente y obtener su consentimiento previo para su uso.
- **Documento: Política de cookies.** Esta política debe incluir:
 - Qué cookies se utilizan.
 - Para qué finalidad.
 - Cómo el usuario puede desactivar o gestionar las cookies.
 - Instrucciones claras para el consentimiento del usuario.

9. Mecanismos para el ejercicio de derechos

- **Obligación:** La empresa debe facilitar a los usuarios mecanismos para ejercer sus derechos (acceso, rectificación, supresión, etc.).
- **Documento: Procedimientos para el ejercicio de derechos.** Este documento debe establecer:
 - Cómo los usuarios pueden solicitar acceso a sus datos.
 - Procedimiento para la rectificación o eliminación de datos.
 - Plazos para responder a las solicitudes de los usuarios (máximo 1 mes).

10. Formación del personal

- **Obligación:** La empresa debe asegurarse de que los empleados que manejan datos personales reciban formación sobre el cumplimiento del RGPD y cómo manejar los datos de forma segura.
- **Documento: Registro de formación.** Este documento debe detallar las fechas, contenidos y asistentes a las sesiones de formación sobre protección de datos.

11. Responsable de protección de datos (DPO)

- **Obligación:** En ciertas circunstancias (por ejemplo, si el tratamiento de datos es a gran escala), la empresa debe designar un Responsable de Protección de Datos (DPO).
- **Documento: Nombramiento del DPO.** Debe quedar documentado quién es el DPO, sus funciones y cómo los usuarios pueden contactar con él.

12. Cláusulas de confidencialidad

IES Isidra de Guzmán	 IES Isidra de Guzmán
Desarrollo Aplicaciones Multiplataforma	Curso 2025/2026
Tema 1: Sistemas de almacenamiento de la información	Legislación sobre protección de datos

- **Obligación:** Los empleados que tienen acceso a datos personales deben firmar compromisos de confidencialidad para garantizar que respetarán las políticas internas de protección de datos.
- **Documento:** **Cláusulas de confidencialidad firmadas** por los empleados.

13. Auditorías internas

- **Obligación:** La empresa debe realizar auditorías periódicas para revisar el cumplimiento del RGPD.
- **Documento:** **Informe de auditoría interna.** Este documento debe incluir los hallazgos, posibles incumplimientos y medidas correctivas adoptadas.

Conclusión:

Estos son los principales documentos y obligaciones que una empresa debe implementar para cumplir con el RGPD. El cumplimiento adecuado requiere un enfoque proactivo y continuo, y la creación de políticas claras, registros detallados y una estructura que garantice la seguridad y privacidad de los datos personales.

2.2.1. Ejemplo de aplicación del RGPD

Una tienda online que vende productos tecnológicos en la Unión Europea debe cumplir con el RGPD porque maneja los datos personales de sus clientes, como nombre, dirección, correo electrónico, y detalles de pago. Esta tienda utiliza los datos para procesar pedidos, enviar comunicaciones promocionales, y gestionar el servicio de atención al cliente.

Aplicación del RGPD

1. Recogida de datos: Licitud, lealtad y transparencia

- **Licitud:** La tienda solo puede procesar los datos personales con una base legal adecuada. Para procesar un pedido, utiliza la base legal del **cumplimiento de un contrato**, ya que necesita los datos para cumplir con las obligaciones del contrato de compra (por ejemplo, envío del producto).
- **Transparencia:** La tienda debe informar al cliente, de forma clara, sobre cómo se van a usar sus datos. Esto se realiza mediante una **política de privacidad** que debe estar accesible en la web. En ella, se detalla qué datos se recopilan, con qué finalidad, durante cuánto tiempo serán almacenados y si se compartirán con terceros (por ejemplo, con empresas de mensajería).

2. Consentimiento para el uso de datos con fines comerciales

IES Isidra de Guzmán	 IES Isidra de Guzmán
Desarrollo Aplicaciones Multiplataforma	Curso 2025/2026
Tema 1: Sistemas de almacenamiento de la información	Legislación sobre protección de datos

- Si la tienda quiere utilizar el correo electrónico del cliente para enviar boletines o promociones, debe obtener su **consentimiento explícito**. El RGPD requiere que el cliente **acepte de forma activa**, es decir, marcando una casilla que indique claramente que está de acuerdo en recibir comunicaciones comerciales.
- La tienda no puede utilizar casillas premarcadas para obtener este consentimiento, y el cliente debe poder retirar el consentimiento fácilmente, por ejemplo, a través de un enlace para darse de baja en cada correo promocional.

3. Minimización de datos y limitación de la finalidad

- **Minimización de datos:** La tienda solo debe pedir los datos que realmente necesita para procesar el pedido, como el nombre, dirección de entrega y detalles de pago. No debería solicitar información innecesaria, como la profesión del cliente, si no es relevante para el servicio.
- **Limitación de la finalidad:** Los datos recogidos para realizar la compra solo deben utilizarse para ese fin. Si la tienda desea utilizar esos datos para otro propósito, como realizar estudios de mercado, debe informar previamente al cliente y, si es necesario, obtener su consentimiento.

4. Exactitud y actualización de los datos

- Los datos deben ser **precisos y actualizados**. Si un cliente cambia su dirección, la tienda debe actualizar la base de datos para que los futuros pedidos lleguen a la nueva dirección. Si los datos son incorrectos, podría resultar en entregas fallidas, y la tienda podría ser responsable de no cumplir con este principio del RGPD.

5. Derechos del cliente: Acceso, rectificación, supresión y portabilidad

- **Derecho de acceso:** Si un cliente solicita saber qué datos tiene la tienda sobre él, la empresa está obligada a proporcionarle una copia de esa información sin cobrarle nada (salvo en casos excepcionales). El cliente puede pedir esta información en cualquier momento.
- **Derecho de rectificación:** Si un cliente ve que alguno de sus datos es incorrecto, puede pedir a la tienda que lo corrija.
- **Derecho de supresión (derecho al olvido):** Un cliente puede pedir que se eliminen sus datos una vez que ya no son necesarios para la finalidad original (por ejemplo, cuando se haya completado el pedido y no sea necesario almacenar más los datos por cuestiones fiscales o legales).
- **Derecho a la portabilidad:** Si un cliente desea cambiar de proveedor (por ejemplo, a otra tienda online), puede solicitar que la tienda le proporcione sus datos en un formato legible para que los transfiera a otro servicio.

6. Seguridad de los datos: Integridad y confidencialidad

IES Isidra de Guzmán	 IES Isidra de Guzmán
Desarrollo Aplicaciones Multiplataforma	Curso 2025/2026
Tema 1: Sistemas de almacenamiento de la información	Legislación sobre protección de datos

- La tienda debe implementar medidas de seguridad adecuadas para proteger los datos personales frente a accesos no autorizados, pérdidas o robos. Esto incluye cifrar la información de pago y utilizar conexiones seguras (HTTPS) para todas las transacciones en línea.
- También debe tener políticas claras sobre quién dentro de la empresa puede acceder a los datos personales y asegurar que solo el personal necesario tenga acceso.

7. Notificación de brechas de seguridad

- Si ocurre una **brecha de seguridad** en la que se vean comprometidos los datos personales de los clientes (por ejemplo, un ciberataque que exponga los números de tarjeta de crédito), la tienda está obligada a notificar a la autoridad de protección de datos (en España, la AEPD) **en un plazo máximo de 72 horas**.
- Si la fuga supone un alto riesgo para los derechos de los usuarios (por ejemplo, datos de pago), la tienda también debe informar directamente a los clientes afectados para que tomen medidas adecuadas.

Conclusión

En este caso, el RGPD garantiza que los datos personales de los clientes se manejan de manera segura, transparente y con respeto a sus derechos. La tienda debe asegurarse de cumplir con todas las obligaciones para evitar sanciones, que pueden ser elevadas, y para mantener la confianza de sus clientes.

3. Ley Orgánica de Protección de Datos y Garantía de los Derechos Digitales (LOPDGDD)

La **Ley Orgánica de Protección de Datos y Garantía de los Derechos Digitales (LOPDGDD)** es la normativa española que **complementa** el **Reglamento General de Protección de Datos (RGPD)**, adaptando y extendiendo sus disposiciones al marco legal español. Esta ley fue aprobada el **5 de diciembre de 2018**, con el objetivo de especificar y desarrollar las normas establecidas en el RGPD, y añade aspectos importantes relativos a los derechos digitales.

A continuación, se explica en más detalle cómo esta ley complementa el RGPD en España:

IES Isidra de Guzmán	 IES Isidra de Guzmán
Desarrollo Aplicaciones Multiplataforma	Curso 2025/2026
Tema 1: Sistemas de almacenamiento de la información	Legislación sobre protección de datos

1. Adaptación del RGPD al contexto español

La LOPDGDD no reemplaza al RGPD, sino que lo complementa en áreas donde el reglamento permite a los estados miembros realizar adaptaciones. Algunos puntos clave incluyen:

- **Edad de consentimiento digital:** El RGPD permite a los estados miembros establecer la edad mínima para que un menor pueda prestar su consentimiento para el tratamiento de sus datos personales. La LOPDGDD fija esta edad en **14 años**, lo que significa que menores de esa edad necesitan el consentimiento de sus padres o tutores para que sus datos sean tratados.
- **Tratamiento de datos en el ámbito laboral:** La LOPDGDD regula de manera más detallada el uso de los datos personales de los empleados en el entorno laboral, estableciendo límites sobre la monitorización de los trabajadores, como en el caso de correos electrónicos corporativos y el uso de dispositivos tecnológicos.
- **Videovigilancia:** La LOPDGDD incluye disposiciones específicas sobre el uso de cámaras de videovigilancia, asegurando que su uso esté justificado, que los trabajadores y clientes estén informados, y que los datos se mantengan durante el tiempo estrictamente necesario.

2. Garantía de los Derechos Digitales

- Una de las principales innovaciones de la LOPDGDD es la inclusión de un capítulo dedicado a los **derechos digitales**. Estos derechos están alineados con la evolución de las nuevas tecnologías y buscan garantizar un uso responsable y equilibrado de la tecnología en distintos ámbitos. Algunos de los derechos más destacados son:
- **Derecho a la desconexión digital en el ámbito laboral:** Los empleados tienen el derecho a no responder correos electrónicos ni mensajes fuera de su horario laboral, con el fin de respetar su tiempo de descanso y conciliación entre la vida personal y laboral. Las empresas deben definir políticas internas que garanticen este derecho.
- **Derecho a la intimidad en el uso de dispositivos digitales:** Los trabajadores tienen derecho a la protección de su intimidad en el uso de los dispositivos tecnológicos puestos a su disposición por la empresa (ordenadores, móviles, etc.). Las empresas deben establecer políticas claras sobre el uso personal de estos dispositivos y respetar la privacidad de sus empleados.
- **Derecho al olvido en búsquedas de internet:** Los usuarios pueden solicitar la eliminación de sus datos personales de los motores de búsqueda en casos donde la información que aparece sea obsoleta, irrelevante o no tenga un interés público.

IES Isidra de Guzmán	 IES Isidra de Guzmán
Desarrollo Aplicaciones Multiplataforma	Curso 2025/2026
Tema 1: Sistemas de almacenamiento de la información	Legislación sobre protección de datos

- **Derecho a la educación digital:** Se reconoce el derecho de los ciudadanos a recibir una educación que promueva un uso responsable y seguro de internet y las tecnologías digitales, con especial atención a la protección de los menores.

3. Tratamiento de datos en el ámbito laboral

La LOPDGDD introduce regulaciones específicas en relación con el tratamiento de datos de los trabajadores en el ámbito laboral, complementando el RGPD. Estos incluyen:

- **Control del uso de dispositivos:** Las empresas pueden establecer controles sobre el uso de los dispositivos tecnológicos proporcionados a sus empleados, pero deben informar de forma clara a los trabajadores sobre cómo se implementan dichos controles.
- **Uso de sistemas de videovigilancia:** Se permite el uso de sistemas de videovigilancia para garantizar la seguridad, siempre que se respeten los derechos de los empleados y se les informe adecuadamente de la existencia de las cámaras. También se regula la posibilidad de utilizar grabaciones en casos de conducta ilícita o disciplinaria.
- **Geolocalización:** Si la empresa utiliza dispositivos de geolocalización para controlar la ubicación de sus empleados, deben cumplir con requisitos de proporcionalidad, transparencia y respeto a la intimidad.

4. Régimen sancionador

La LOPDGDD, en conjunto con el RGPD, introduce un régimen de sanciones que varía dependiendo de la gravedad de la infracción. Las sanciones pueden ser muy severas, llegando hasta los 20 millones de euros o el 4% de la facturación anual global de la empresa, según el RGPD. No obstante, la LOPDGDD proporciona más claridad sobre la **graduación de las sanciones** en función de factores como:

- La naturaleza y gravedad de la infracción.
- El carácter intencional o negligente del infractor.
- Las medidas correctivas implementadas por la empresa tras la infracción.

5. Delegado de Protección de Datos (DPO)

Aunque el RGPD ya establece la obligación de designar un Delegado de Protección de Datos (DPO) en ciertas organizaciones, la LOPDGDD proporciona más detalle sobre los casos en los que es obligatorio contar con un DPO en España. Las empresas obligadas a nombrar un DPO incluyen:

- Aquellas que tratan datos a gran escala (por ejemplo, hospitales).
- Organizaciones públicas.

IES Isidra de Guzmán	 IES Isidra de Guzmán
Desarrollo Aplicaciones Multiplataforma	Curso 2025/2026
Tema 1: Sistemas de almacenamiento de la información	Legislación sobre protección de datos

- Empresas que realizan seguimiento de comportamientos a gran escala (por ejemplo, empresas de marketing).

El DPO actúa como un punto de contacto entre la empresa y la Agencia Española de Protección de Datos (AEPD), asegurando que la empresa cumpla con la normativa de protección de datos.

6. Fines históricos, estadísticos y de investigación científica

La LOPDGDD también incluye disposiciones específicas sobre el tratamiento de datos personales para fines históricos, estadísticos y de investigación científica. Esto es importante en sectores como la sanidad, donde se permite tratar datos personales, incluso sensibles, siempre que se implementen garantías adecuadas de seguridad y se respeten los derechos de los individuos.

7. Autoridad de control: AEPD

La Agencia Española de Protección de Datos (AEPD) es el organismo encargado de supervisar el cumplimiento de las leyes de protección de datos en España. La LOPDGDD refuerza el papel de la AEPD, facultándola para imponer sanciones y orientar a las organizaciones en la correcta aplicación de la normativa.

URL: <https://www.aepd.es/>

Resumen de los aspectos claves de la LOPDGDD:

- Edad mínima de consentimiento digital en España: **14 años**.
- Regulación sobre el uso de dispositivos y videovigilancia en el ámbito laboral.
- Derechos digitales (desconexión digital, derecho al olvido, intimidad en el uso de dispositivos).
- Mayor detalle sobre el tratamiento de datos en áreas específicas como la investigación o el ámbito laboral.
- Obligación de designar un DPO en ciertos casos.
- Régimen de sanciones específicas para infracciones de la normativa.

En conclusión, la **LOPDGDD** es una normativa crucial en España que adapta el RGPD a la realidad legal y social del país, aportando un marco más detallado en áreas como los derechos digitales, el tratamiento de datos en el ámbito laboral, y la regulación de la videovigilancia y la

IES Isidra de Guzmán	 IES Isidra de Guzmán
Desarrollo Aplicaciones Multiplataforma	Curso 2025/2026
Tema 1: Sistemas de almacenamiento de la información	Legislación sobre protección de datos

geolocalización. Además, refuerza el papel de la **AEPD** como autoridad supervisora y complementa el régimen sancionador del RGPD con criterios específicos para España.

3.1. Derechos de los titulares de datos

Los derechos de los titulares de los datos son fundamentales en el **Reglamento General de Protección de Datos (RGPD)** y en la **Ley Orgánica de Protección de Datos y Garantía de los Derechos Digitales (LOPDGDD)**.

Estos derechos permiten a las personas controlar cómo se utilizan sus datos personales y garantizan que puedan ejercer un control sobre su privacidad.

A continuación, se explica con más detalle cada uno de estos derechos y cómo se aplican, acompañados de ejemplos prácticos:

1. Derecho de acceso

Este derecho permite a las personas saber si una organización está tratando sus datos personales y, en caso afirmativo, obtener una copia de esos datos.

Ejemplo: María tiene una cuenta en una tienda online y quiere saber qué información sobre ella se almacena en sus sistemas. María puede ejercer su **derecho de acceso** enviando una solicitud a la tienda. La empresa está obligada a proporcionarle una copia de todos sus datos personales que almacena, incluyendo su nombre, dirección, historial de compras, y otros datos relevantes, sin coste alguno.

Obligación de la empresa:

- Proporcionar a la persona acceso a sus datos dentro de un plazo de **1 mes** desde la recepción de la solicitud.
- Facilitar una copia de los datos en un formato legible.

2. Derecho de rectificación

Las personas tienen derecho a solicitar que se corrijan los datos personales que sean incorrectos o estén incompletos.

IES Isidra de Guzmán	 IES Isidra de Guzmán
Desarrollo Aplicaciones Multiplataforma	Curso 2025/2026
Tema 1: Sistemas de almacenamiento de la información	Legislación sobre protección de datos

Ejemplo: Juan se da cuenta de que su nombre está mal escrito en el sistema de su proveedor de servicios de internet. Puede enviar una solicitud de **rectificación** para que corrijan su nombre. La empresa está obligada a corregir los errores sin demora injustificada.

Obligación de la empresa:

- Corregir cualquier dato inexacto o incompleto sin demora.
- Informar al titular de los datos cuando la rectificación haya sido realizada.

3. Derecho de supresión (derecho al olvido)

Este derecho permite a los individuos solicitar que sus datos personales sean eliminados bajo ciertas circunstancias, como cuando ya no son necesarios para los fines por los cuales fueron recogidos o cuando el individuo retira su consentimiento.

Ejemplo: Sara ha creado una cuenta en una red social, pero decide que ya no quiere que sus datos estén en esa plataforma. Puede ejercer su **derecho de supresión**, solicitando a la red social que elimine su cuenta y toda la información relacionada con ella. Si no hay una razón legal para mantener sus datos, la red social deberá eliminarlos.

Obligación de la empresa:

- Eliminar los datos personales cuando ya no sean necesarios o si el usuario retira su consentimiento, salvo que existan otras razones legales para retenerlos (como obligaciones legales o razones de interés público).

4. Derecho a la limitación del tratamiento

Este derecho permite a las personas solicitar que su información sea marcada para que no se procese más en ciertas circunstancias. Esto no implica la eliminación de los datos, sino que se limiten las operaciones que pueden realizarse sobre ellos.

Ejemplo: Manuel está disputando la exactitud de algunos datos que una empresa tiene sobre él. Mientras la empresa verifica la exactitud de los datos, Manuel puede solicitar la **limitación del tratamiento** para que los datos no sean procesados hasta que se resuelva la disputa.

Obligación de la empresa:

- Restringir el uso de los datos mientras se resuelvan las cuestiones planteadas por el titular.
- Notificar al titular de los datos una vez que la limitación se haya levantado.

IES Isidra de Guzmán	 IES Isidra de Guzmán
Desarrollo Aplicaciones Multiplataforma	Curso 2025/2026
Tema 1: Sistemas de almacenamiento de la información	Legislación sobre protección de datos

5. Derecho a la portabilidad de los datos

Este derecho permite a las personas recibir sus datos personales en un formato estructurado, de uso común y legible por máquina, para que puedan ser transferidos a otro responsable del tratamiento sin impedimentos. Es especialmente útil en sectores como las telecomunicaciones o la banca, donde los clientes pueden cambiar de proveedor fácilmente.

Ejemplo: Claudia quiere cambiar de proveedor de servicios de música en streaming. Para no perder su lista de canciones, Claudia puede ejercer su **derecho a la portabilidad**, solicitando que sus datos (listas de reproducción, historial de canciones, etc.) sean transferidos a su nuevo proveedor de servicios de música.

Obligación de la empresa:

- Proporcionar los datos en un formato digital común y legible por máquina.
- Facilitar la transferencia directa de los datos a otra empresa si el titular lo solicita y es técnicamente posible.

6. Derecho de oposición

Este derecho permite a los titulares de datos oponerse al tratamiento de sus datos personales cuando se utilicen con fines como el marketing directo, la elaboración de perfiles, o el tratamiento en interés público o legítimo de la empresa.

Ejemplo: Carlos empieza a recibir correos promocionales de una tienda online tras realizar una compra. Carlos puede ejercer su **derecho de oposición**, solicitando que la tienda deje de enviarle correos publicitarios. La tienda debe cesar el envío de los correos inmediatamente.

Obligación de la empresa:

- Detener el tratamiento de los datos personales para los fines específicos a los que el titular se opone, salvo que existan motivos legítimos imperiosos que prevalezcan sobre los intereses, derechos y libertades del titular.

7. Derecho a no ser objeto de decisiones automatizadas

Este derecho garantiza que los individuos no sean objeto de decisiones basadas únicamente en el tratamiento automatizado, como los algoritmos, que puedan tener efectos legales o significativos sobre ellos.

Ejemplo: Lucía solicita un préstamo online, pero su solicitud es rechazada automáticamente por un sistema basado en un algoritmo. Lucía tiene el derecho a solicitar una revisión

IES Isidra de Guzmán	 IES Isidra de Guzmán
Desarrollo Aplicaciones Multiplataforma	Curso 2025/2026
Tema 1: Sistemas de almacenamiento de la información	Legislación sobre protección de datos

manual de su caso, para asegurarse de que no fue discriminada o tratada injustamente por un proceso automatizado.

Obligación de la empresa:

Informar a los titulares si sus decisiones están basadas únicamente en un tratamiento automatizado, y ofrecer la posibilidad de solicitar una revisión humana de la decisión.

3.2. Responsabilidad proactiva y evaluaciones de impacto

El **principio de responsabilidad proactiva o accountability** implica que las organizaciones, y en particular los administradores de bases de datos, deben garantizar que se toman todas las medidas adecuadas para cumplir con el RGPD, y además deben ser capaces de **demostrar** dicho cumplimiento. Este principio no solo exige que se cumplan las normativas, sino que obliga a las organizaciones a ser **proactivas** y no meramente reactivas ante incidentes relacionados con la privacidad de los datos.

3.2.1. Medidas proactivas que deben tomar los administradores de bases de datos

1. Políticas y procedimientos de privacidad claros:

- Las organizaciones deben tener políticas internas documentadas sobre cómo se gestionan los datos personales, cubriendo aspectos como la recogida, almacenamiento, acceso, tratamiento, y eliminación de los datos.
- Estas políticas deben ser comunicadas a todo el personal, y es recomendable realizar **formaciones periódicas** para asegurar que todos los empleados conocen las responsabilidades y normativas relacionadas con la protección de datos.

2. Registro de actividades de tratamiento:

- Todas las organizaciones que tratan datos personales de forma habitual deben llevar un **registro de actividades de tratamiento**. Este registro incluye información detallada sobre los datos que se procesan, para qué fines, qué medidas de seguridad

IES Isidra de Guzmán	 IES Isidra de Guzmán
Desarrollo Aplicaciones Multiplataforma	Curso 2025/2026
Tema 1: Sistemas de almacenamiento de la información	Legislación sobre protección de datos

se han implementado, quién es el responsable del tratamiento, y los plazos de conservación.

3. Medidas de seguridad técnicas y organizativas:

- Las medidas deben ajustarse a la sensibilidad de los datos que se gestionan. Por ejemplo, los datos sensibles (como los relacionados con la salud) requieren un nivel de protección más alto, incluyendo **cifrado**, **anonimización** y **pseudonimización**.
- Las organizaciones también deben asegurar que solo el personal autorizado tenga acceso a los datos, y que se implementen controles de acceso adecuados.

4. Notificación de brechas de seguridad:

- En caso de una brecha de seguridad que afecte los datos personales, las empresas tienen la obligación de **notificar** a la autoridad competente en un plazo de 72 horas. Si la brecha implica un riesgo elevado para los derechos de los individuos, también es necesario informar directamente a las personas afectadas.

3.3. Evaluaciones de Impacto en la Protección de Datos (EIPD)

Las **Evaluaciones de Impacto en la Protección de Datos (EIPD)** son un instrumento clave dentro de la responsabilidad proactiva. Su objetivo es identificar los riesgos que una operación de tratamiento de datos puede tener sobre la privacidad de los individuos y tomar las medidas necesarias para mitigarlos.

¿Cuándo es obligatorio realizar una EIPD?

El RGPD establece que las EIPD deben realizarse **antes** de llevar a cabo cualquier tratamiento de datos personales que sea susceptible de generar un **alto riesgo** para los derechos y libertades de las personas físicas. En particular, es obligatorio en los siguientes casos:

1. **Evaluaciones sistemáticas y exhaustivas de aspectos personales** de las personas físicas que se basen en el tratamiento automatizado, incluida la elaboración de perfiles, y que produzcan efectos jurídicos o afecten significativamente a los individuos.
 - **Ejemplo:** Sistemas que determinan automáticamente si un cliente puede obtener un crédito, basados en análisis automatizados de datos personales.
2. **Tratamientos a gran escala de categorías especiales de datos (datos sensibles)**, como los relacionados con la salud, la religión, o la orientación sexual.
 - **Ejemplo:** Un hospital que maneja historiales médicos de miles de pacientes.

IES Isidra de Guzmán	 IES Isidra de Guzmán
Desarrollo Aplicaciones Multiplataforma	Curso 2025/2026
Tema 1: Sistemas de almacenamiento de la información	Legislación sobre protección de datos

3. Vigilancia sistemática a gran escala de una zona de acceso público.

- **Ejemplo:** El uso de cámaras de videovigilancia en un centro comercial que capturan imágenes de los clientes.

3.3.1. Pasos para realizar una EIPD

1. Descripción del tratamiento:

- Especificar la naturaleza del tratamiento, el propósito, los datos personales que se procesan, y las operaciones que se realizan sobre esos datos.

2. Evaluación de la necesidad y proporcionalidad:

- Justificar que el tratamiento es **necesario** para los fines perseguidos y que se procesan solo los datos mínimos necesarios (principio de minimización de datos).
- Asegurar que las medidas adoptadas son proporcionadas a los fines del tratamiento y respetan los derechos de los titulares.

3. Identificación de riesgos:

- Identificar los posibles riesgos que el tratamiento podría suponer para la privacidad de los usuarios. Estos riesgos pueden incluir la pérdida, el acceso no autorizado, la alteración o el robo de los datos personales.
- Algunos riesgos pueden tener consecuencias legales, económicas o reputacionales graves para los titulares de los datos.

4. Medidas para mitigar los riesgos

- Proponer soluciones para reducir o eliminar los riesgos identificados. Estas medidas pueden incluir la **implementación de medidas de seguridad adicionales**, como cifrado, control de acceso, pseudonimización, o la reducción de la cantidad de datos procesados.
- También es posible cambiar el diseño del tratamiento para minimizar los riesgos (por ejemplo, dividiendo el almacenamiento de datos en varios sistemas).

5. Consulta con la autoridad de protección de datos

- En casos donde los riesgos identificados no pueden ser mitigados adecuadamente, es necesario consultar con la autoridad de protección de datos antes de proceder con el tratamiento. En España, esta autoridad es la **Agencia Española de Protección de Datos (AEPD)**.

IES Isidra de Guzmán	 IES Isidra de Guzmán
Desarrollo Aplicaciones Multiplataforma	Curso 2025/2026
Tema 1: Sistemas de almacenamiento de la información	Legislación sobre protección de datos

3.3.1.1. Ejemplo de EIPD

Una empresa de comercio electrónico planea implementar un sistema de **personalización de anuncios** en su sitio web, basado en el historial de navegación y compras de los usuarios. Como esto implica el tratamiento de grandes volúmenes de datos personales y podría impactar en la privacidad de los usuarios, la empresa decide realizar una **EIPD** antes de introducir el sistema.

- 1. Descripción:** El sistema recopilará el historial de navegación de los usuarios y lo analizará para ofrecer anuncios personalizados. Los datos se procesarán automáticamente para identificar las preferencias de compra de los usuarios.
- 2. Necesidad y proporcionalidad:** La empresa justifica que la personalización de anuncios mejorará la experiencia de usuario y es esencial para su modelo de negocio. Los datos recopilados serán mínimos (historial de navegación y compras) y no se utilizarán datos sensibles.
- 3. Identificación de riesgos:** Los principales riesgos son el acceso no autorizado a los datos de navegación y compras, así como el uso de los datos para otros fines no comunicados previamente a los usuarios.
- 4. Medidas para mitigar riesgos:** La empresa decide utilizar cifrado en todas las transacciones y solo permitirá el acceso a los datos de personalización al personal tendrán la opción de oponerse a la personalización de anuncios.

Este enfoque de responsabilidad proactiva asegura que los **administradores de bases de datos** y las organizaciones no solo cumplan con la normativa, sino que también protejan la privacidad de los individuos en todo momento. Las **EIPD** son esenciales para identificar y mitigar riesgos antes de que ocurran problemas, proporcionando una estructura sólida para el manejo responsable de los datos personales.

IES Isidra de Guzmán	 IES Isidra de Guzmán
Desarrollo Aplicaciones Multiplataforma	Curso 2025/2026
Tema 1: Sistemas de almacenamiento de la información	Legislación sobre protección de datos

3.4. Notificación de brechas de seguridad

Una **brecha de seguridad** (o violación de seguridad de datos personales) ocurre cuando hay un **incidente** que resulta en la destrucción, pérdida, alteración, divulgación no autorizada o acceso a datos personales, ya sea accidental o ilícitamente.

Este tipo de incidentes puede afectar la confidencialidad, integridad o disponibilidad de los datos personales y puede tener graves consecuencias para los individuos, como el robo de identidad, fraudes financieros o la pérdida de privacidad.

En caso de una brecha de seguridad que comprometa los datos personales, las empresas están obligadas a notificar a la autoridad de protección de datos dentro de las 72 horas. Además, si la brecha supone un riesgo significativo, también deben informar a los usuarios afectados.

3.4.1. Tipos comunes de brechas de seguridad

- **Pérdida o robo de dispositivos:** Cuando un portátil, teléfono móvil o dispositivo de almacenamiento que contiene datos personales se pierde o es robado.
- **Acceso no autorizado:** Cuando una persona o grupo accede a datos personales sin el permiso adecuado, como en el caso de ciberataques o acceso indebido por empleados.
- **Ataques informáticos (hacking):** Incluye la vulneración de bases de datos a través de malware, ransomware o phishing que compromete datos personales.
- **Divulgación accidental de datos:** Ocurre cuando, por error, se envían correos electrónicos con datos personales a la persona equivocada o se publican datos en un lugar accesible para personas no autorizadas.

3.4.2. Proceso de notificación de una brecha de seguridad

El **Reglamento General de Protección de Datos (RGPD)** establece un procedimiento específico que las empresas y organizaciones deben seguir si se produce una brecha de seguridad que afecta a los datos personales:

IES Isidra de Guzmán	 IES Isidra de Guzmán
Desarrollo Aplicaciones Multiplataforma	Curso 2025/2026
Tema 1: Sistemas de almacenamiento de la información	Legislación sobre protección de datos

1. Evaluación inicial de la brecha

- **Primera reacción:** Tan pronto como la empresa sea consciente de la brecha, debe actuar inmediatamente para contener el incidente, investigarlo y mitigar los posibles daños.
- **Evaluación del impacto:** La organización debe determinar si la brecha ha afectado a datos personales y, en su caso, la **naturaleza** de los datos comprometidos (por ejemplo, si se trata de datos sensibles, financieros o información identificativa).

2. Notificación a la autoridad de control

- **Plazo de 72 horas:** Si la brecha de seguridad implica un riesgo para los derechos y libertades de las personas afectadas, la organización tiene la **obligación de notificar** a la **Agencia Española de Protección de Datos (AEPD)** o la autoridad correspondiente **dentro de las 72 horas** desde que se detectó la brecha. Si la notificación no se realiza dentro de este plazo, se debe justificar el motivo del retraso.
- **Contenido de la notificación:** La notificación debe incluir la siguiente información:
 - **Naturaleza de la brecha:** Una descripción de lo sucedido, especificando el tipo de datos personales comprometidos y la cantidad de personas afectadas.
 - **Consecuencias:** Una descripción de las **consecuencias probables** o reales de la brecha para los afectados.
 - **Medidas adoptadas:** Detalles sobre las medidas que la organización ha implementado o planea implementar para **mitigar** los efectos de la brecha, evitar nuevas fugas y corregir las vulnerabilidades.
 - **Datos de contacto del DPO:** Información del **Delegado de Protección de Datos (DPO)** o del responsable de la organización encargado de gestionar la brecha para facilitar el contacto con la autoridad de control.

3. Notificación a los afectados

- **Cuándo es necesario informar a los afectados:** Si la brecha supone un **alto riesgo** para los derechos y libertades de los individuos (por ejemplo, en caso de que se comprometan datos sensibles como números de tarjetas de crédito o historiales médicos), es necesario informar **directamente** a los afectados sin demora injustificada.
- **Contenido de la notificación a los afectados:** Los afectados deben recibir información clara sobre:

IES Isidra de Guzmán	 IES Isidra de Guzmán
Desarrollo Aplicaciones Multiplataforma	Curso 2025/2026
Tema 1: Sistemas de almacenamiento de la información	Legislación sobre protección de datos

- La **naturaleza de la brecha**.
- Las **consecuencias** potenciales para ellos.
- Las medidas adoptadas por la empresa para mitigar el impacto.
- Recomendaciones sobre las **medidas que los individuos pueden tomar** para protegerse (por ejemplo, cambiar contraseñas o vigilar sus cuentas bancarias).
- Datos de contacto para obtener más información (por ejemplo, del DPO).

4. Documentación interna

- **Registro obligatorio:** Incluso en los casos en los que no sea necesario notificar a la AEPD ni a los individuos, la empresa debe **documentar todas las brechas de seguridad**, incluidos los detalles del incidente, las acciones tomadas y las razones por las que se decidió no notificar.
- Esta documentación es esencial para demostrar el cumplimiento con el RGPD en caso de auditorías o inspecciones.

Conclusión

La **notificación de brechas de seguridad** es un componente esencial del cumplimiento del RGPD. Las organizaciones deben estar preparadas para actuar rápidamente ante una brecha, evaluando su gravedad, notificando a la autoridad de control y a los individuos cuando sea necesario, y documentando todas las acciones realizadas. Esto no solo garantiza la transparencia y el cumplimiento normativo, sino que también contribuye a la protección de los derechos y libertades de los titulares de los datos.

3.4.2.1. Ejemplo 1: Fuga de datos en un banco

Un banco sufre un **ataque informático** que compromete los datos de **50000 clientes**, incluyendo números de cuenta bancaria y direcciones personales. Al detectar la brecha, el banco debe:

1. **Evaluar el impacto:** Determina que los datos comprometidos podrían ser utilizados para fraudes financieros, por lo que se considera que el riesgo es **alto**.

IES Isidra de Guzmán	 IES Isidra de Guzmán
Desarrollo Aplicaciones Multiplataforma	Curso 2025/2026
Tema 1: Sistemas de almacenamiento de la información	Legislación sobre protección de datos

2. **Notificar a la AEPD:** Informa a la AEPD dentro de las 72 horas, describiendo el tipo de datos comprometidos y las medidas de seguridad adicionales que han implementado (por ejemplo, cerrar temporalmente el acceso online de las cuentas).
3. **Informar a los clientes afectados:** El banco envía correos electrónicos y cartas a todos los clientes afectados, explicando la naturaleza de la brecha y recomendando que supervisen sus cuentas bancarias para detectar actividades sospechosas.
4. **Documentar la brecha:** El banco documenta internamente todo lo relacionado con la brecha, incluyendo el incidente, las medidas adoptadas y el proceso de notificación.

3.4.2.2. *Ejemplo 2: Pérdida de un portátil con datos cifrados*

Un empleado de una clínica de salud pierde un portátil que contiene **historiales médicos** de 200 pacientes. Sin embargo, los datos en el portátil están **cifrados**, lo que reduce significativamente el riesgo de acceso no autorizado. La clínica:

1. **Evalúa el riesgo:** Determina que, debido al cifrado, el riesgo para los pacientes es bajo, por lo que decide **no notificar a los pacientes** ni a la AEPD.
2. **Documentación interna:** La clínica documenta la brecha y las razones por las que no se procedió a la notificación, en caso de una futura auditoría.